

Rapporto di Vulnerability Assessment: Analisi delle Vulnerabilità su Host Target

Corso di Cybersecurity — Epicode Institute of Technology

1. Sintesi

Il presente rapporto descrive l'attività di analisi delle minacce e di Vulnerability Assessment eseguita all'interno di un ambiente di laboratorio controllato. L'obiettivo principale è stato mappare la superficie di attacco di un host bersaglio (Metasploitable), identificare le vulnerabilità attive e proporre le relative strategie di mitigazione basate sui principali framework di sicurezza.

2. Introduzione

La corretta segmentazione della rete e il monitoraggio costante dei servizi esposti sono pilastri fondamentali per garantire la continuità operativa di qualsiasi infrastruttura aziendale. In questo scenario, l'attività di analisi è stata condotta simulando un approccio di tipo Red Teaming/Pentesting su una macchina target situata all'interno di una rete isolata, protetta e instradata tramite un firewall/router PfSense.

3. Panorama delle Minacce e Analisi del Target

3.1 Fase di Reconnaissance Attiva e Port Scanning

La prima fase operativa ha previsto l'interazione diretta con l'host bersaglio per mappare le porte TCP/UDP aperte, determinare i sistemi operativi sottostanti e catturare i banner dei servizi in esecuzione (Fingerprinting). La scansione è stata eseguita tramite lo strumento Nmap, impostando un profilo di scansione stealth (SYN Scan) e un timing ottimizzato per la rete locale locale.

- **Target IP:** 192.168.50.101
- **Gateway/Firewall di transito:** 192.168.56.100 (PfSense)
- **Comando eseguito su Kali Linux:** `sudo nmap -sS -sV -O -T4 192.168.50.101 -oA metasploitable_scan`

```
(kali@kali)-[~]
$ sudo nmap -sS -sV -O -T4 192.168.50.101 -oA metasploitable_scan
[sudo] password for kali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-09 11:04 -0400
Nmap scan report for 192.168.50.101
Host is up (0.0010s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login?
514/tcp   open  shell        Netkit rshd
1099/tcp  open  java-rmi      GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ccproxy-ftp?
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc           VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.15 - 2.6.26 (likely embedded)
Network Distance: 2 hops
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 174.56 seconds
```

3.2 Analisi dei Servizi Critici Rilevati da Nmap

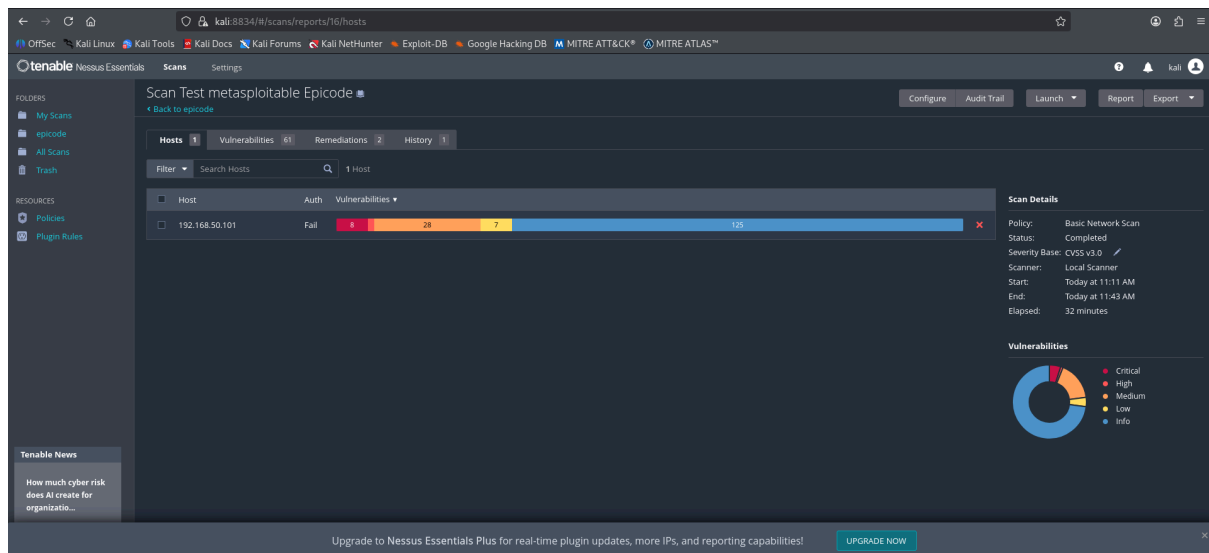
Dall'output di Nmap sono emerse gravi anomalie e servizi obsoleti esposti direttamente sulla rete:

- **Porta 21 (FTP):** Servizio **vsftpd 2.3.4**, noto per contenere una backdoor nativa nel codice sorgente.
- **Porta 23 (Telnet):** Protocollo di gestione remota obsoleto che trasmette credenziali e dati interamente in chiaro.
- **Porta 1524 (Ingreslock):** Presenza di una bind shell che offre un accesso remoto diretto con privilegi di root senza richiedere autenticazione.
- **Porte 139/445 (Samba):** Versioni non patchate per la condivisione di file, sensibili a vulnerabilità di esecuzione remota del codice (RCE).

4. Analisi delle Vulnerabilità Emergenti (Nessus Assessment)

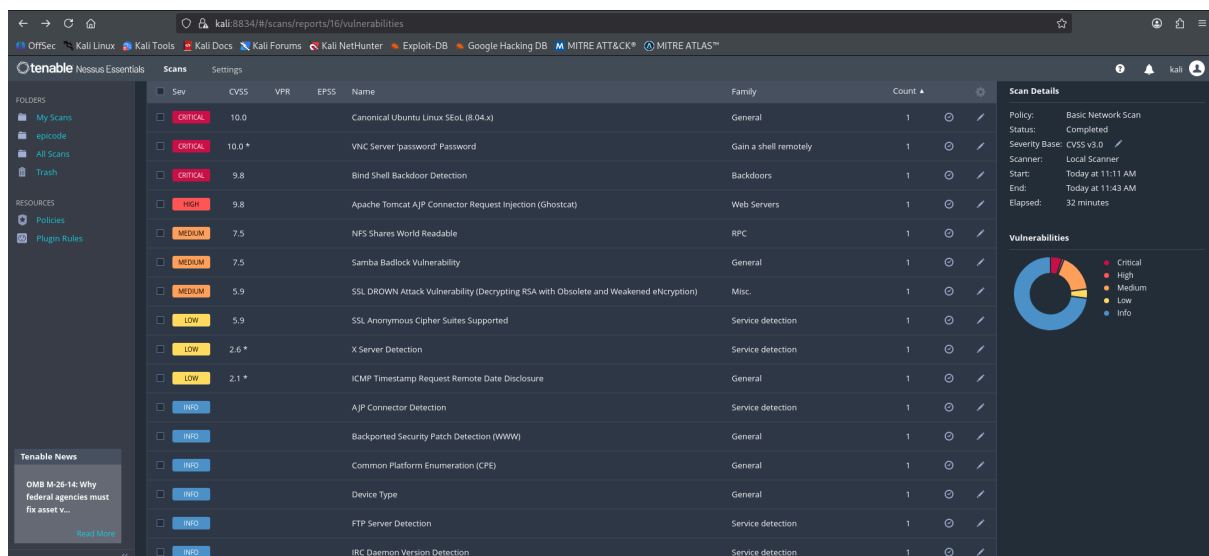
Per estendere le capacità di analisi e validare i vettori d'attacco, è stata eseguita una scansione automatizzata approfondita tramite il software **Tenable Nessus Essentials**, utilizzando la policy *Basic Network Scan*.

La scansione ha impiegato un tempo complessivo di **32 minuti**, interrogando l'host attraverso il routing di PfSense e rilevando un totale di **61 vulnerabilità attive**.



4.1 Classificazione delle Vulnerabilità Rilevate

Le minacce identificate all'interno della scheda *Vulnerabilities* di Nessus sono state categorizzate in base al sistema di punteggio CVSS:



1. **Canonical Ubuntu Linux SEoL (8.04.x) [CVSS 10.0]:** Il sistema operativo ha superato la data di End-of-Life. La mancanza di patch di sicurezza correttive espone il kernel a exploit pubblici di Privilege Escalation.
2. **VNC Server 'password' Password [CVSS 10.0]:** Errore critico di configurazione (Misconfiguration). La password del desktop remoto corrisponde alla stringa predefinita "password", permettendo un accesso grafico immediato a chiunque.
3. **Bind Shell Backdoor Detection [CVSS 9.8]:** Presenza di un canale d'accesso malevolo permanente sulla porta 1425 che espone il prompt dei comandi di root.

4. **Apache Tomcat AJP Connector - Ghostcat [CVSS 9.8]:** Falla di tipo File Read/Inclusion (CVE-2020-1938) che consente a un attaccante non autenticato di leggere file riservati della web application.

5. Strategie di Difesa e Raccomandazioni (Remediation Advice)

Per mitigare l'elevato livello di rischio riscontrato sull'host, si raccomanda l'adozione immediata delle seguenti misure difensive:

- **Inasprimento delle Politiche sul Firewall (PfSense):** Configurare regole di filtraggio rigide per bloccare il traffico perimetrale "East-West" verso le porte critiche non necessarie (es. 1524, 3306, 5432).
- **Aggiornamento dei Sistemi (Lifecycle Management):** Procedere alla dismissione o all'avanzamento di versione (Upgrade) dei sistemi operativi e dei software giunti al termine del ciclo di vita (EoL).
- **Sanificazione delle Credenziali:** Implementare policy stringenti per la complessità delle password e disattivare gli accessi di default o privi di autenticazione sui servizi di amministrazione remota (VNC, MySQL).
- **Transizione a Protocolli Sicuri (Data in Transit):** Sostituire i servizi in chiaro come Telnet (porta 23) in favore di protocolli crittografati forti come SSH (porta 22) basati su autenticazione a chiavi.

6. Conclusioni

L'attività svolta ha evidenziato come l'utilizzo combinato di tecniche di port scanning (Nmap) e strumenti di vulnerability scanning (Nessus) sia cruciale per ottenere una mappatura realistica delle falle di sicurezza. La cybersecurity deve essere intesa come un processo di revisione continua; l'adozione di un approccio preventivo di auditing e la tempestiva applicazione delle patch rimangono le uniche barriere efficaci contro il cybercrime strutturato.

Documento redatto per finalità di analisi didattica e strategica.